Romain Jacquet **BTS SIO 2**
06/10/2026

Compte rendu TP 2.4 : Test d'intrusion : Phase II Scanning

Sommaire

Introduction **2**
I. Préparation de l'environnement 2
II. Le puissant outil de scanning Nmap 2
Ex1 : Qu'est-ce que httpd ? 2
Ex2 : Scan du réseau local 3
Ex3 : Détection du système d'exploitation (-O) 3
Ex4 : Détection des versions de services (-sV) 3
Ex5 : Utilisation de CherryTree 4
Ex6 : Scan agressif (-A) 5
Ex7 : Mise à jour de CherryTree 6
III. Le scanner Nessus 6
1) Téléchargement de Nessus 6
2) Installation sur Kali Linux 6
3) Démarrage du service 7
4) Premier accès à Nessus 7
5) Création du compte Nessus Essentials 8
Ex1 : Lancement d'un scan Nessus 8
Ex2 : Exportation du rapport 12
Ex3 : Scanner la VM Seven SP1 (à réaliser) 13
Conclusion **13**

Introduction

Dans ce TP, j'ai découvert le scanning avec Nmap et Nessus. Nmap permet d'identifier les ports ouverts et les services d'une machine, tandis que Nessus détecte ses failles de sécurité.

J'ai aussi compris qu'il faut toujours avoir une autorisation avant de scanner une machine et respecter les règles de sécurité.

I. Préparation de l'environnement

J'ai repris les mêmes machines virtuelles que lors des TP précédents :

- La cible : ma VM Windows Seven, d'adresse IP 172.30.12.51
- L'attaquant : ma VM Kali Linux, d'adresse IP 172.30.12.50

J'ai démarré les deux machines, ouvert un terminal sur Kali, puis j'ai élevé mes privilèges avec la commande sudo su, nécessaire pour certains scans Nmap qui requièrent les droits root (comme la détection d'OS ou le scan agressif).

II. Le puissant outil de scanning Nmap

Ex1 : Qu'est-ce que httpd ?

httpd désigne le daemon (processus serveur) HTTP, c'est-à-dire le programme qui fait tourner un serveur web et qui écoute les requêtes HTTP/HTTPS pour servir les pages web (par exemple Apache httpd).

Scan de base sur la machine Windows

J'ai lancé un premier scan simple sur l'adresse IP de ma machine Windows :

```
nmap 172.30.12.51
```

```
┌──(root㉿kali)-[/home/romain]
└─# nmap 172.30.12.51
Starting Nmap 7.99 ( https://nmap.org ) at 2026-09-29 08:43 +0200
Nmap scan report for 172.30.12.51
Host is up (0.0011s latency).
Not shown: 991 closed tcp ports (reset)
PORT      STATE SERVICE
135/tcp   open  msrpc
139/tcp   open  netbios-ssn
445/tcp   open  microsoft-ds
49152/tcp open  unknown
49153/tcp open  unknown
49154/tcp open  unknown
49155/tcp open  unknown
49156/tcp open  unknown
49157/tcp open  unknown
MAC Address: 00:0C:29:7D:F5:50 (VMware)

Nmap done: 1 IP address (1 host up) scanned in 1.96 seconds
```

Résultat du scan nmap de base sur la machine Windows (172.30.12.51)

J'ai obtenu la liste des ports ouverts avec leurs services : 135/tcp (msrpc), 139/tcp (netbios-ssn), 445/tcp (microsoft-ds), ainsi que plusieurs ports hauts (49152 à 49157) dont le service est encore "unknown" à ce stade.

Ex2 : Scan du réseau local

Pour scanner tout le réseau local en une seule commande, j'utilise l'adresse du réseau avec le masque en notation CIDR :

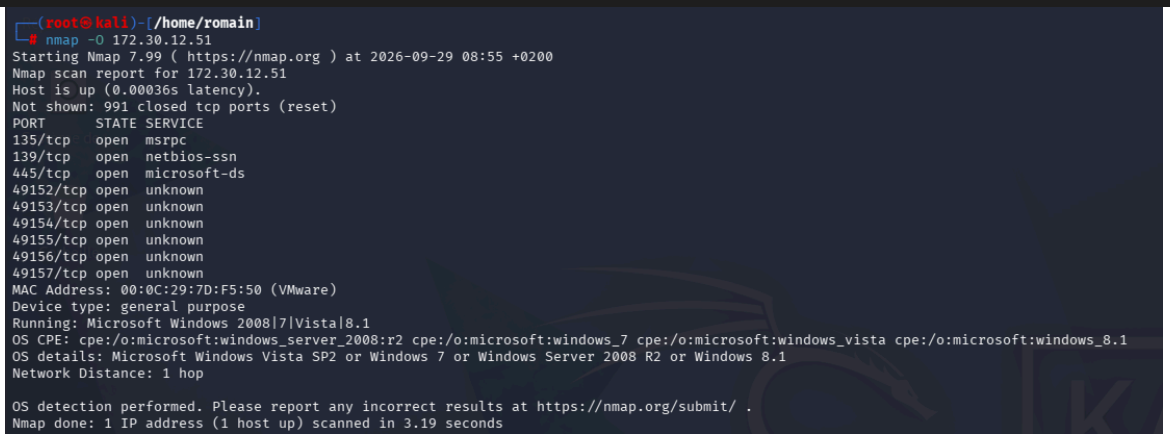
```
nmap 172.30.12.0/24
```

Si le scan paraît long, j'ai noté qu'il est possible d'appuyer sur la barre d'espace pour voir la progression en temps réel.

Ex3 : Détection du système d'exploitation (-O)

J'ai utilisé l'argument -O pour essayer de détecter le système d'exploitation de ma cible :

```
nmap -O 172.30.12.51
```



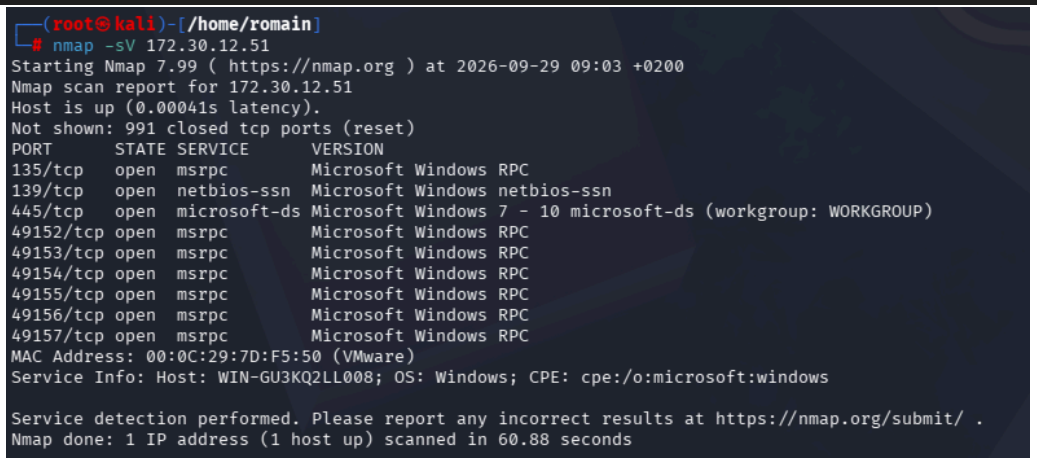
Résultat de la détection d'OS avec nmap -O

Le résultat donne une estimation : "Running: Microsoft Windows 2008|7|Vista|8.1", avec plusieurs versions possibles (Vista SP2, Windows 7, Windows Server 2008 R2, ou Windows 8.1). La version exacte n'est pas encore certaine à ce stade.

Ex4 : Détection des versions de services (-sV)

J'ai utilisé l'argument -sV pour afficher les versions précises des services exécutés sur les différents ports :

```
nmap -sV 172.30.12.51
```

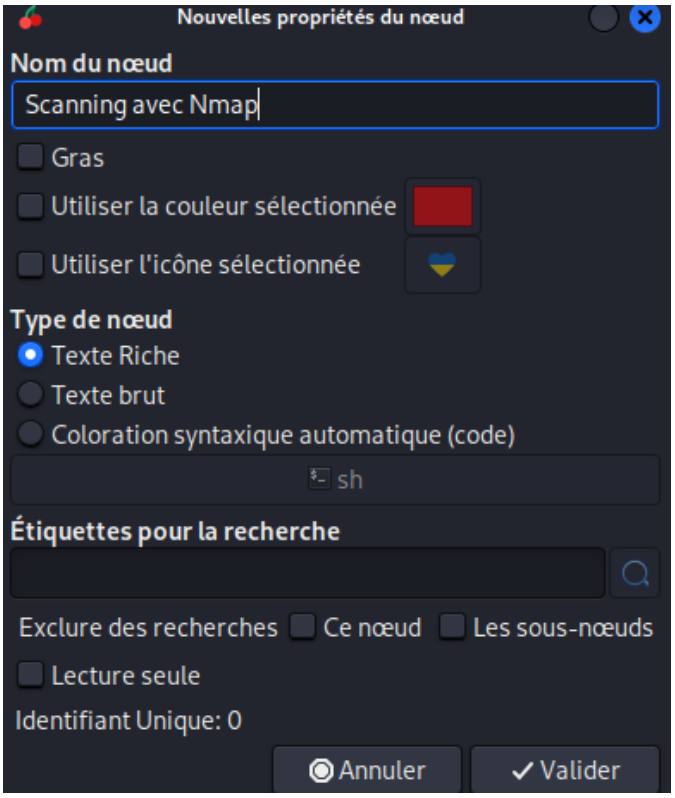


Résultat du scan nmap -sV avec les versions des services

Le résultat précise maintenant que le port 445 utilise "Microsoft Windows 7 - 10 microsoft-ds (workgroup: WORKGROUP)", et donne le nom de l'hôte (WIN-GU3KQ2LL008). Ce scan a pris plus de temps que le précédent (environ une minute), mais les informations obtenues sont bien plus précises.

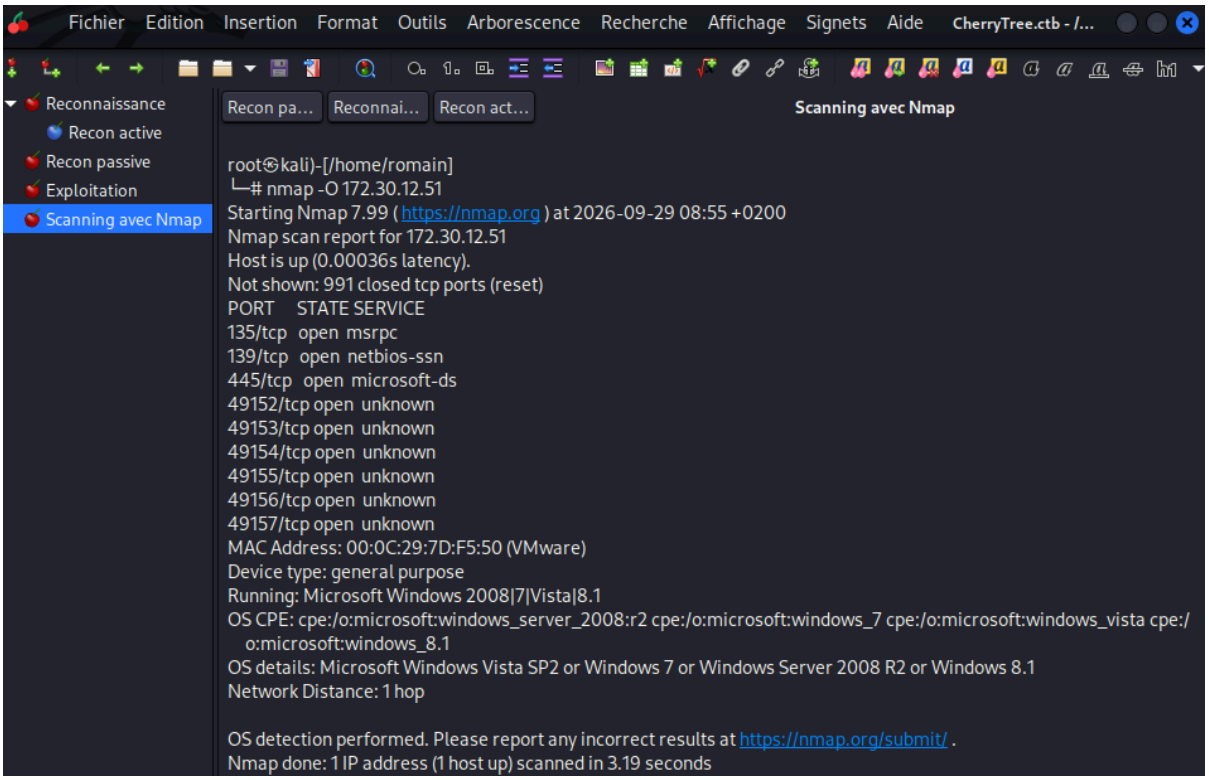
Ex5 : Utilisation de CherryTree

J'ai ouvert CherryTree et créé un nouveau nœud nommé "Scanning avec Nmap" via la boîte de dialogue "Nouvelles propriétés du nœud" :



Création du nœud "Scanning avec Nmap" dans CherryTree

J'ai ensuite fait un copier-coller du résultat des deux commandes précédentes (-O et -sV) dans ce nœud :



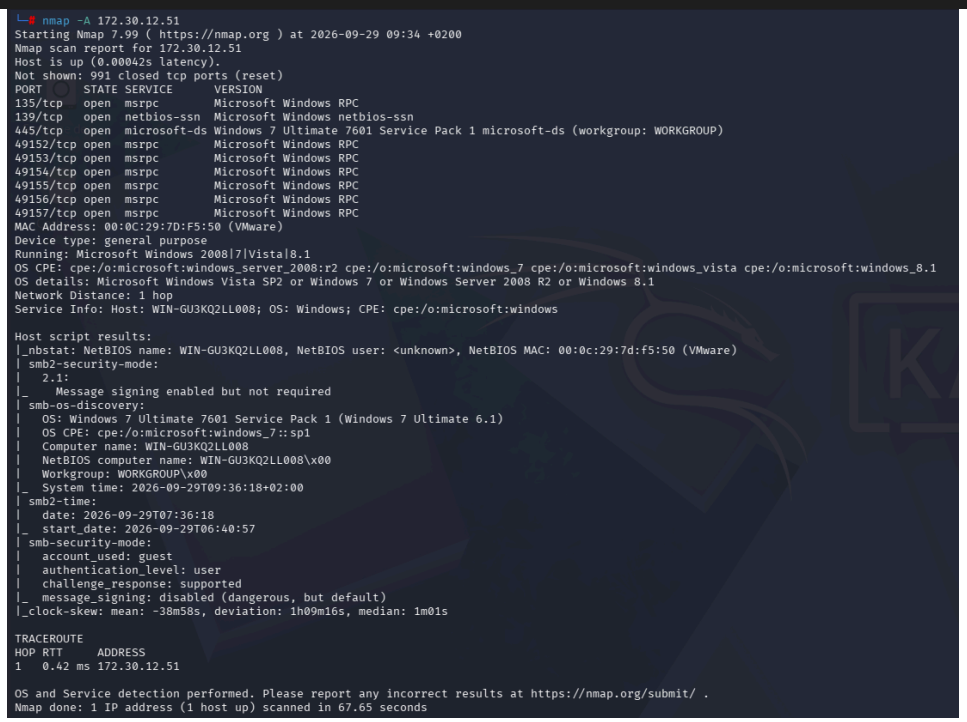
Nœud "Scanning avec Nmap" rempli avec le résultat du scan -O

Ex6 : Scan agressif (-A)

Le scan nmap -A, appelé scan agressif, combine la détection d'OS, la détection de version des services, l'exécution de scripts par défaut et le traceroute. Il donne beaucoup plus d'informations, mais génère aussi beaucoup plus de trafic : il faut l'utiliser avec prudence, car il peut être assimilé à une attaque DOS sur le serveur ciblé.

J'ai testé cet argument sur ma machine Windows :

```
nmap -A 172.30.12.51
```



Résultat du scan agressif nmap -A sur 172.30.12.51

Ce scan m'a donné beaucoup plus d'informations qu'avant. La version de Windows est maintenant précise : "Windows 7 Ultimate 7601 Service Pack 1 (Windows 7 Ultimate 6.1)", alors que le scan -O précédent proposait plusieurs versions possibles. J'ai également obtenu le nom NetBIOS de la machine (WIN-GU3KQ2LL008), le groupe de travail (WORKGROUP), ainsi que des informations sur le protocole SMB (smb2-security-mode, smb-os-discovery).

Le numéro de Service Pack est une information vitale pour la suite du test d'intrusion : il permettra de rechercher des exploits connus pour cette version précise de Windows.

Ex7 : Mise à jour de CherryTree

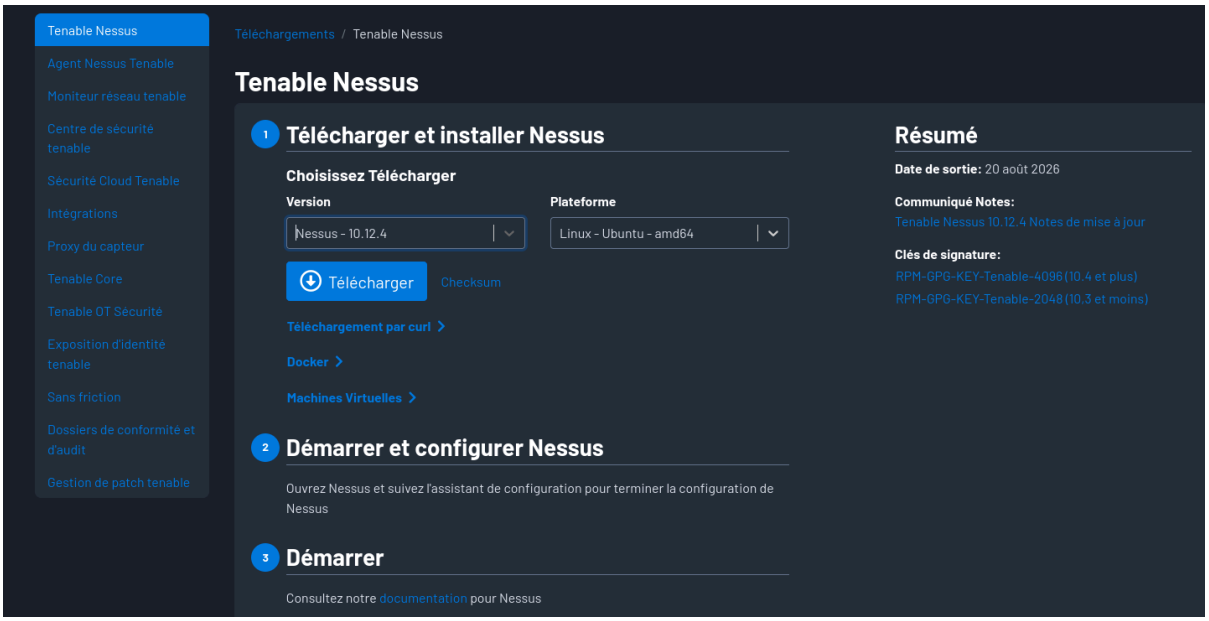
J'ai remplacé les informations collées précédemment dans CherryTree (résultat du scan -O) par ce résultat du scan -A, beaucoup plus détaillé, afin de garder la meilleure source d'information pour la suite du test d'intrusion.

III. Le scanner Nessus

Nessus est un scanner de vulnérabilités très connu, édité par Tenable. Contrairement à Nmap qui identifie les ports et services, Nessus va directement chercher les failles de sécurité connues sur la cible et proposer des recommandations pour les corriger.

1) Téléchargement de Nessus

Je suis allé sur le site officiel de Tenable (https://www.tenable.com/downloads/nessus) et j'ai choisi la version Linux - Ubuntu - amd64, puisque je vais l'installer directement sur ma machine Kali :

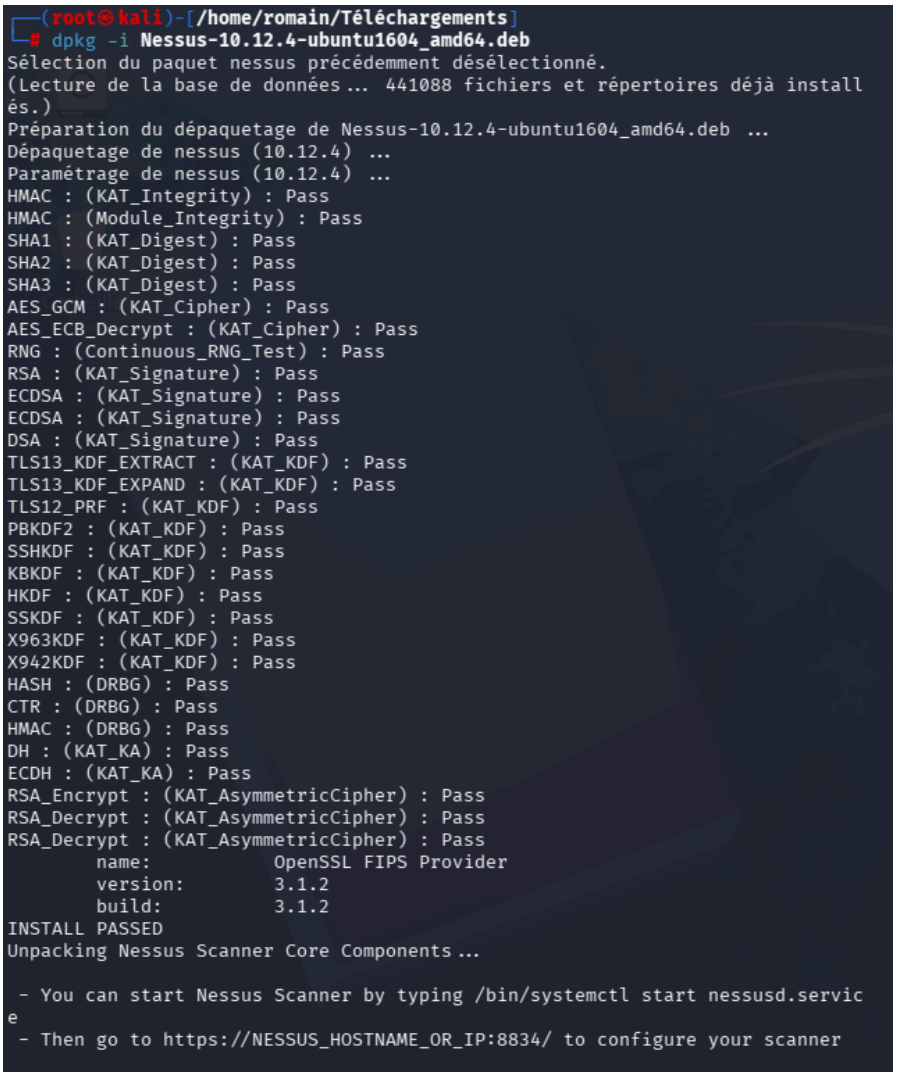


Page de téléchargement de Tenable Nessus (version Linux Ubuntu amd64)

2) Installation sur Kali Linux

Une fois le fichier .deb téléchargé dans le dossier Téléchargements, j'ai lancé l'installation du paquet avec dpkg :

```
dpkg -i Nessus-10.12.4-ubuntu1604_amd64.deb
```



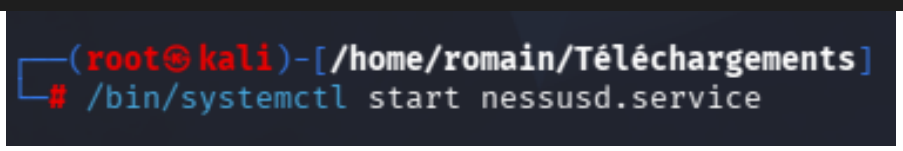
Installation de Nessus avec dpkg -i (vérifications cryptographiques puis dépaquetage)

L'installation s'est terminée avec le message "INSTALL PASSED" et les instructions pour démarrer le service et accéder à l'interface web.

3) Démarrage du service

J'ai démarré le service Nessus avec la commande :

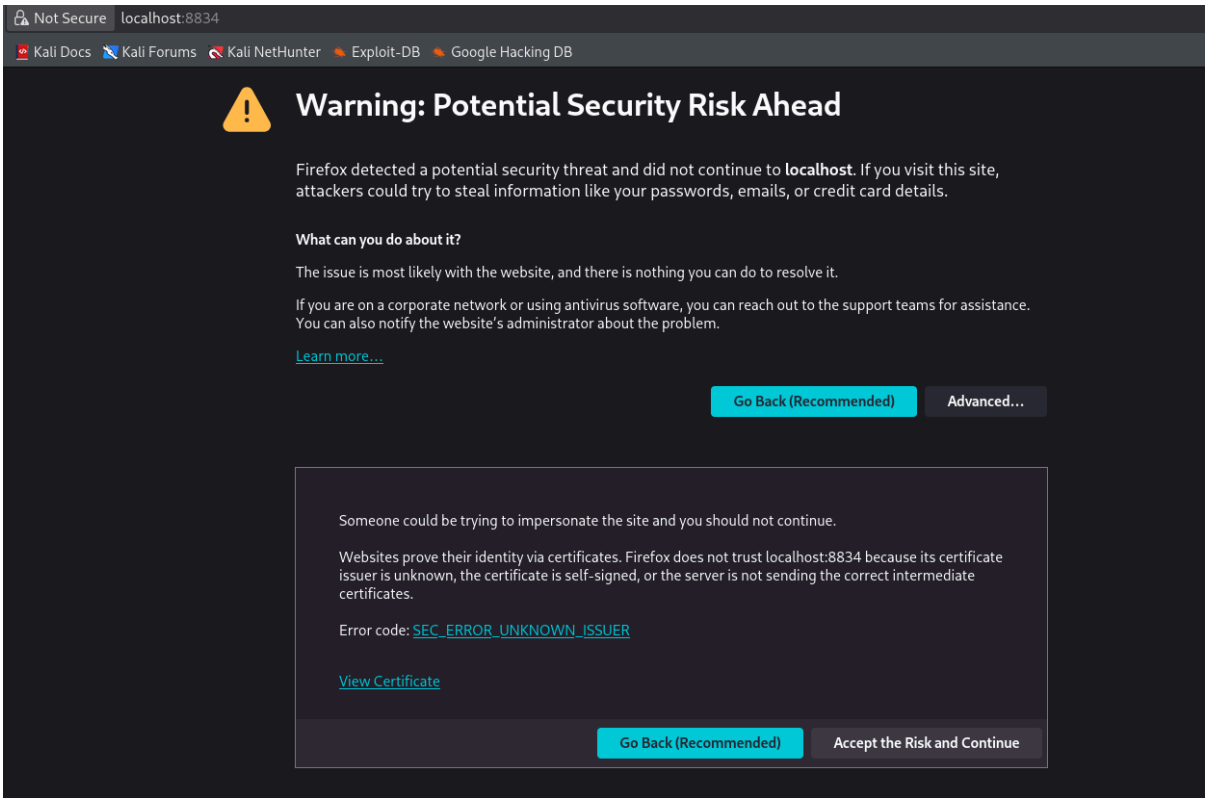
```
/bin/systemctl start nessusd.service
```



Démarrage du service nessusd avec systemctl

4) Premier accès à Nessus

J'ai ouvert mon navigateur et je me suis rendu à l'adresse https://localhost:8834 (l'interface web de Nessus tourne en local sur ma machine Kali). Comme Nessus utilise un certificat auto-signé, Firefox a affiché un avertissement de sécurité :



Avertissement de sécurité Firefox (certificat auto-signé de Nessus)

J'ai cliqué sur Advanced, puis sur Accept the Risk and Continue pour accéder à l'interface de configuration de Nessus.

5) Création du compte Nessus Essentials

Sur l'écran "Welcome to Nessus", j'ai sélectionné Register for Nessus Essentials (la version gratuite, limitée à 16 adresses IP par scanner), puis Continue. J'ai ensuite créé mon compte local avec le nom d'utilisateur romain et le mot de passe azerty123. Nessus télécharge alors ses plugins et les compile : cette étape peut durer 10 à 20 minutes, et l'interface reste limitée tant que la compilation n'est pas terminée.

Si le téléchargement des plugins échoue (message "Download Failed"), il suffit d'arrêter le service, de mettre à jour les plugins à la main, puis de relancer le service :

```
/bin/systemctl stop nessusd.service
/opt/nessus/sbin/nessuscli update --all
/bin/systemctl start nessusd.service
```

Ex1 : Lancement d'un scan Nessus

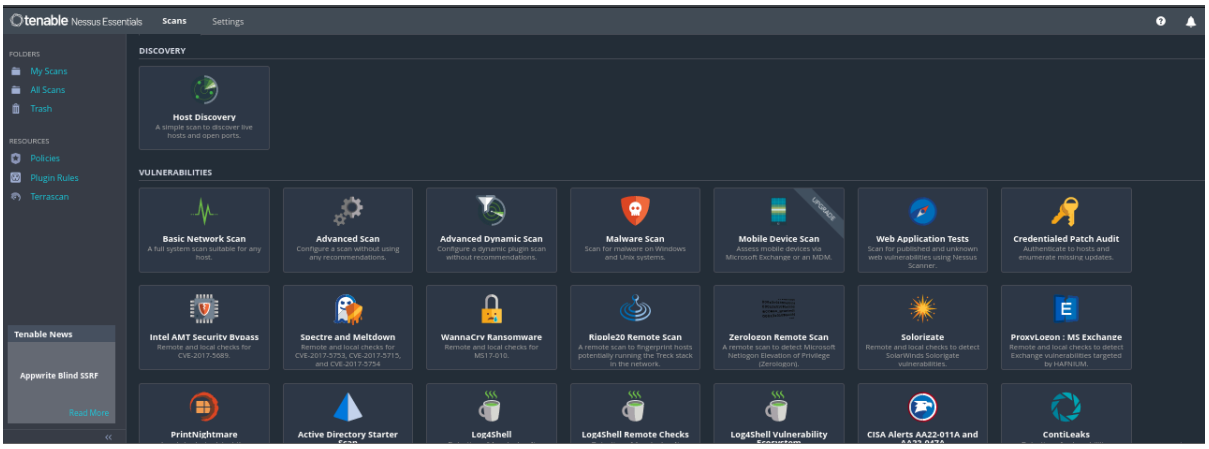
J'ai suivi la procédure complète sur l'exemple du support de cours (scan d'un serveur OWASP Broken Web Apps, 192.168.0.160). Il me reste à la refaire sur ma propre VM (Ex4).

1) J'ai d'abord lancé le service Nessus depuis un terminal en root :



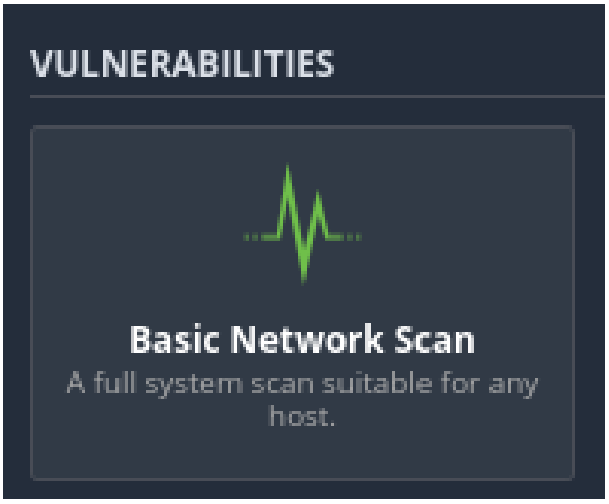
Démarrage du service Nessus (sudo su puis systemctl start nessusd.service)

2) Je me suis connecté à https://kali:8834 puis j'ai cliqué sur New Scan. Nessus a affiché la liste des modèles de scan : la section Discovery (simple découverte d'hôtes) et la section Vulnerabilities, avec de nombreux modèles (Basic Network Scan, Advanced Scan, Malware Scan, Web Application Tests, etc.). Certains modèles sont réservés aux versions payantes.



Liste des modèles de scan proposés par Nessus

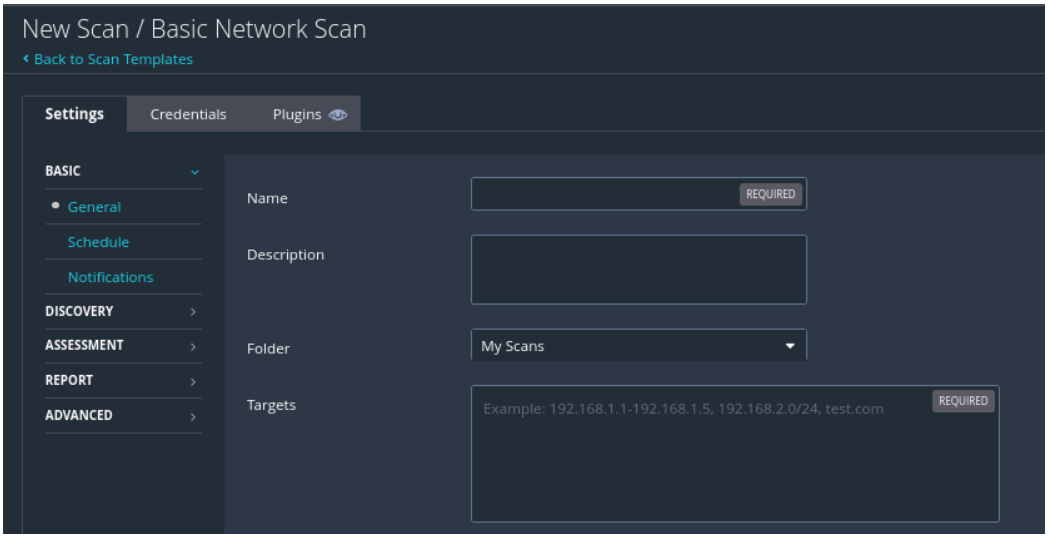
3) J'ai choisi le modèle Basic Network Scan : c'est un scan complet du système, adapté à n'importe quel hôte.



Modèle Basic Network Scan

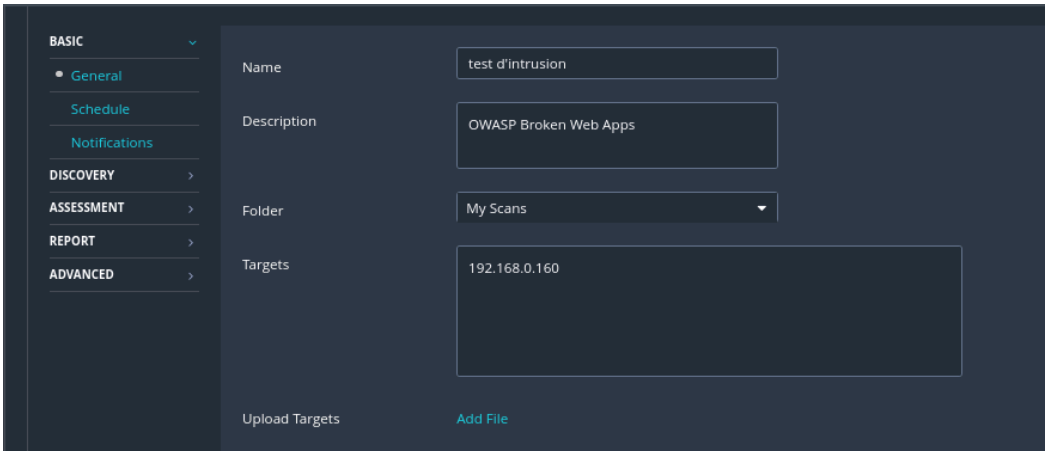
4) Un formulaire s'est ouvert. L'onglet Settings > General demande un nom (Name), une description, le dossier de sauvegarde (Folder) et surtout les cibles (Targets) : l'adresse IP,

la plage ou le nom de domaine à scanner. Les champs Name et Targets sont obligatoires (REQUIRED).



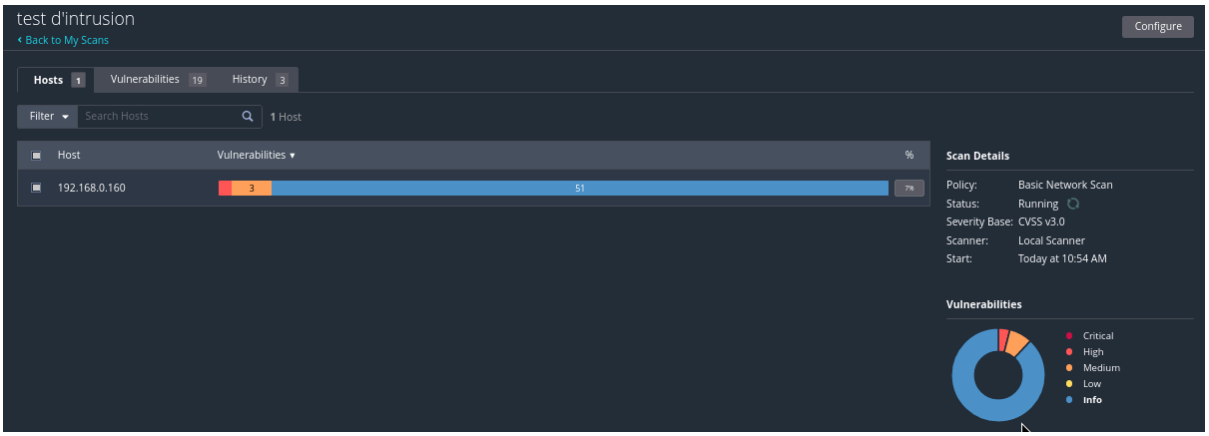
Formulaire de création du scan (champs vides)

5) J'ai rempli le formulaire : nom "test d'intrusion", description "OWASP Broken Web Apps" et cible 192.168.0.160. Il est aussi possible de planifier le scan (Schedule) ou de recevoir une notification par mail à la fin (Notifications). J'ai sauvegardé puis lancé le scan, qui peut durer longtemps.



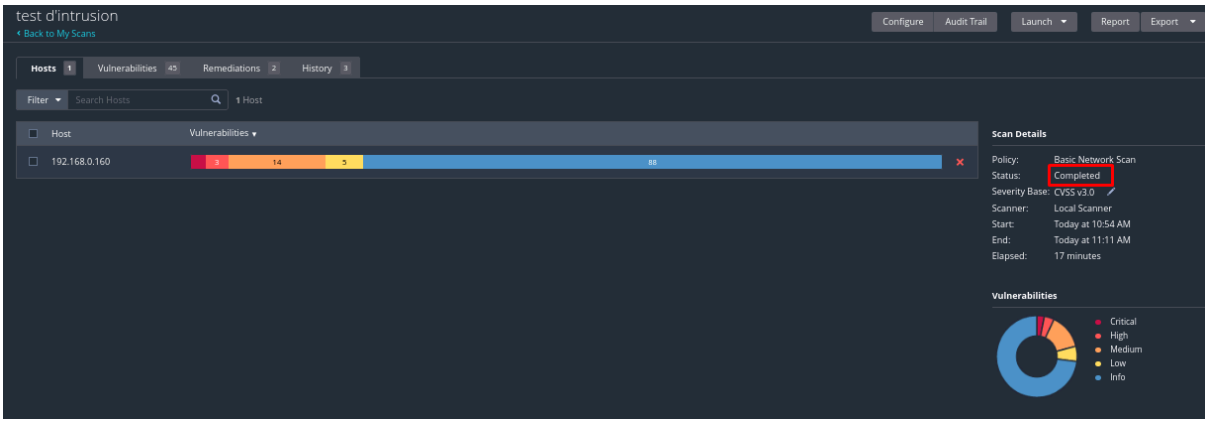
Formulaire rempli (exemple du cours)

6) Au bout de quelques minutes, j'ai vu dans l'onglet Hosts l'hôte scanné avec une barre colorée qui se remplissait au fur et à mesure (rouge = critique, orange = moyenne, bleu = information). Le statut était Running, avec la date de début et un camembert récapitulatif des vulnérabilités déjà trouvées.



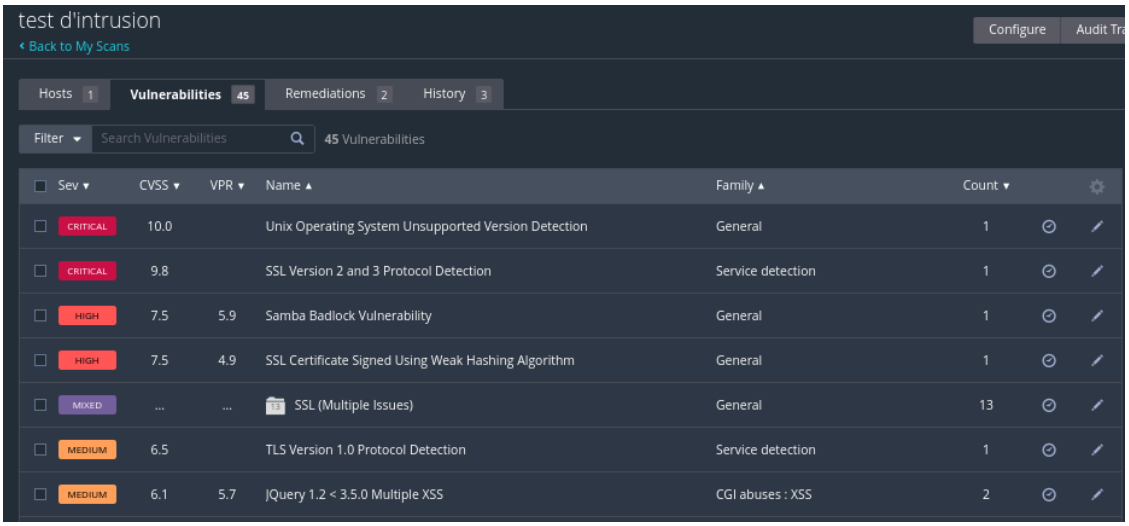
Scan en cours d'exécution (statut Running)

7) Au bout d'environ 15 minutes, le statut est passé à Completed (encadré en rouge). La barre indique la répartition des résultats par niveau de gravité, et les onglets Vulnerabilities (45) et Remediations (2) étaient disponibles. Ici, le scan a duré 17 minutes.



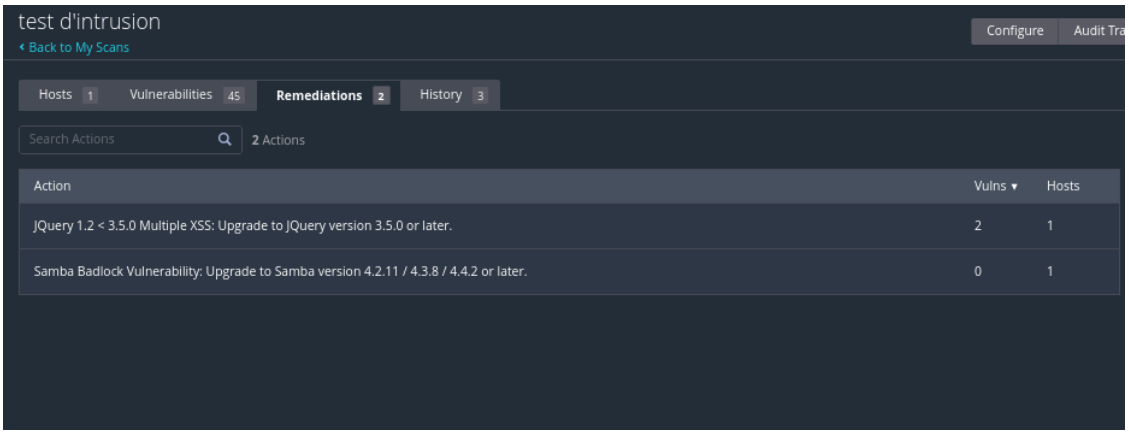
Scan terminé (statut Completed)

8) J'ai consulté l'onglet Vulnerabilities, qui liste toutes les failles trouvées avec leur gravité (Critical, High, Medium...), leur score CVSS, leur nom, leur famille et le nombre d'occurrences. J'y ai trouvé par exemple "Unix Operating System Unsupported Version Detection" (CVSS 10.0, critique) et "SSL Version 2 and 3 Protocol Detection" (CVSS 9.8, critique).



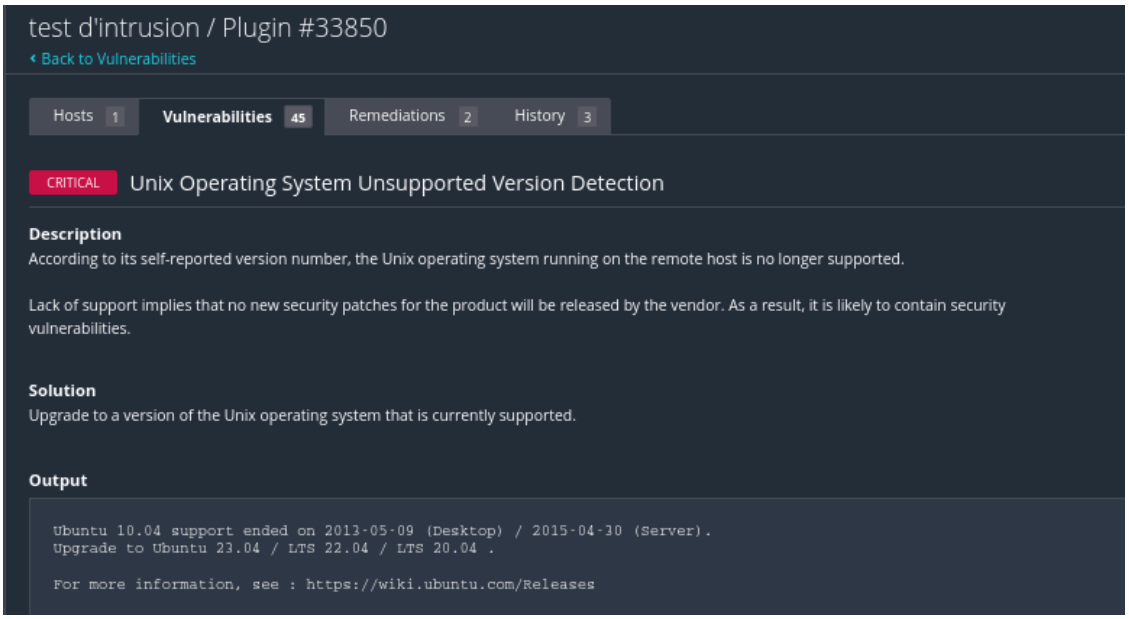
Onglet Vulnerabilities : liste des failles classées par gravité

9) J'ai ensuite ouvert l'onglet Remediations, qui donne quelques conseils concrets pour corriger les problèmes, par exemple mettre à jour jQuery vers la version 3.5.0 ou plus récente, ou mettre à jour Samba vers une version corrigée.



Onglet Remediations : actions correctives proposées

10) En cliquant sur une vulnérabilité, j'ai obtenu sa description, la solution recommandée et la sortie (Output) du plugin. Ici, le système d'exploitation de la cible n'est plus supporté (Ubuntu 10.04 en fin de support depuis 2013 pour le bureau et 2015 pour le serveur), donc il ne reçoit plus de correctifs de sécurité : la solution est de passer à une version supportée.

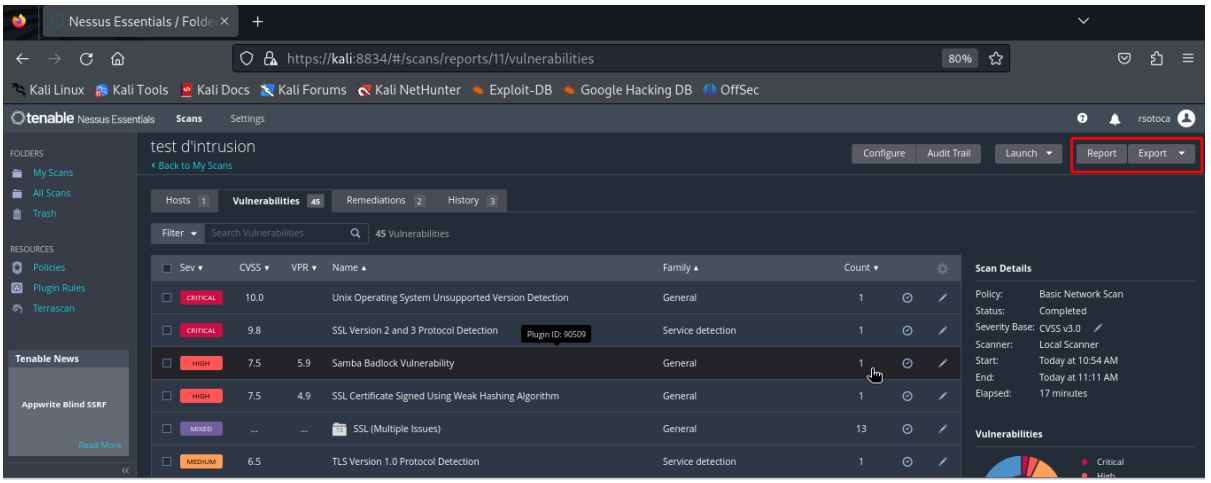


Détail d'une vulnérabilité critique (Plugin #33850)

J'ai constaté que Nessus est très puissant : il donne une vue générale de l'état de sécurité d'un serveur ou d'un réseau.

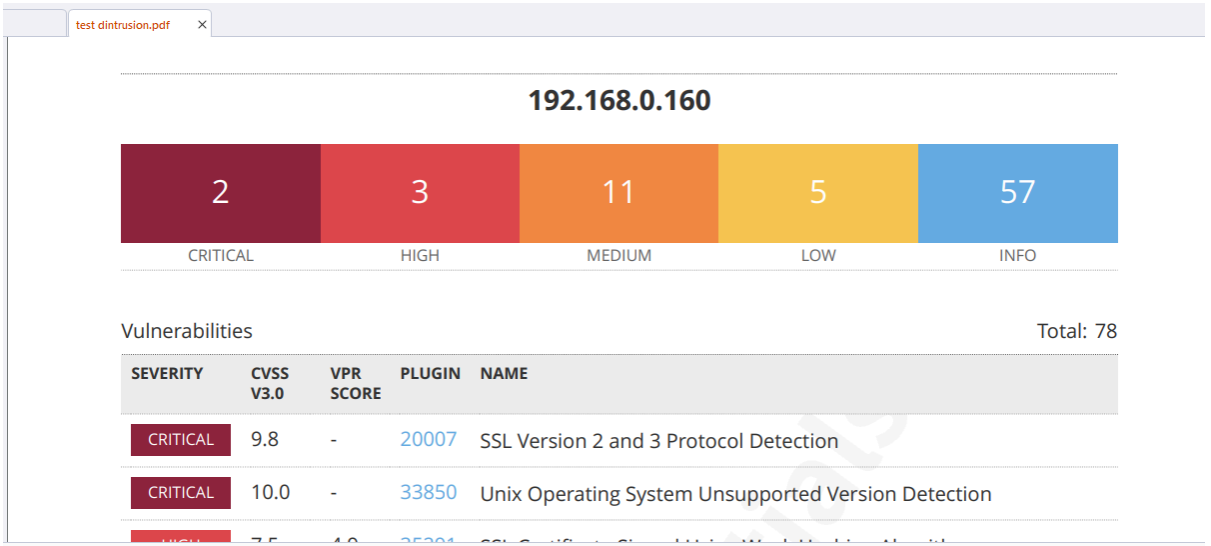
Ex2 : Exportation du rapport

Nessus peut générer un rapport que l'on peut ajouter à la fin du test d'intrusion. Dans la page du scan terminé, j'ai utilisé les boutons Report et Export (encadrés en rouge) en haut à droite pour l'exporter au format PDF.



Boutons Report / Export de la page du scan

J'ai ensuite ouvert le PDF généré (test dintrusion.pdf). Il présente en en-tête le nombre de vulnérabilités par niveau de gravité (ici 2 critiques, 3 élevées, 11 moyennes, 5 faibles et 57 informations, soit 78 au total), puis un tableau avec la gravité, le score CVSS v3.0, le numéro de plugin et le nom de chaque vulnérabilité, classées par ordre de criticité. Le score CVSS v3.0 maximum est 10, atteint pour une sévérité très critique.



Rapport PDF exporté depuis Nessus (exemple du cours)

Ex3 : Scanner la VM Seven SP1 (à réaliser)

Il me reste à refaire exactement la même procédure sur ma propre machine Windows Seven SP1 :

- New Scan > Basic Network Scan, nom "test d'intrusion", cible 172.30.12.51.
- Sauvegarder, lancer le scan et attendre le statut Completed.
- Consulter les onglets Vulnerabilities et Remediations.
- Exporter le rapport en PDF et l'ajouter au rapport final du test d'intrusion.

Je compléterai cette partie avec mes propres captures d'écran une fois le scan terminé.

Conclusion

Ce TP m'a permis de découvrir la phase de scanning d'un test d'intrusion, bien plus intrusive que la reconnaissance passive vue précédemment avec SpiderFoot. J'ai appris à

utiliser Nmap pour découvrir les ports ouverts, les services et le système d'exploitation d'une cible, avec des arguments de plus en plus précis (-O, -sV, -A).

J'ai également installé Nessus et étudié le déroulement complet d'un scan de vulnérabilités : lancement, suivi, lecture des résultats classés par gravité, recommandations de correction et export du rapport PDF, qui pourra être joint au rapport final.

Ce TP confirme l'importance d'être méthodique et prudent lors du scanning : bien documenter chaque résultat dans CherryTree, et toujours garder à l'esprit l'impact que ces outils peuvent avoir sur un réseau de production.